Risk Mitigation Planning

Control Selection (NIST CSF 2.0 · ISO/IEC 27001:2022) · Cost-Benefit · Treatment Strategies · Residual Risk

Treats all 16 risks in the HVMC register using the weighted scores and BIA targets from Risk Evaluation Methods

Project Name	Healthcare IAM Operations Simulation
Organization	Horizon Valley Medical Center (HVMC)
Rubric	Risk Mitigation Planning (Semester 4, Week 11)
Builds on	Risk Assessment Techniques (register, ALE); Risk Evaluation Methods (weighted scores, BIA, exposure register)
Companion file	**HVMC_Risk_Mitigation_Workbook.xlsx** — controls & costs, treatment plan, cost-benefit, residual risk, KPIs, timeline, business alignment (live formulas)
Prepared By	Sabitha S Karanavar
Report Date	October 14, 2026

Rubric Cross-Reference

Rubric requirement	Section	Evidence
Controls selected and documented using NIST CSF and ISO 27001, with detailed rationale	2	16 treatments, each mapped to NIST CSF 2.0 subcategories and ISO/IEC 27001:2022 Annex A controls, with rationale
Cost-benefit analysis	3	ALE-based ROSI and payback for 5 quantified risks; insurance analysis; cost-effectiveness for all controls; budget
Treatment options for all four strategies (mitigate, avoid, transfer, accept)	4	Mitigate 11 risks · Avoid 3 · Transfer 3 · Accept 1; conditions for each
Implementation timelines and resource requirements	5	8-week, 3-phase Gantt; hours per owner; licences and budget per phase
Comprehensive mitigation strategy aligned with business objectives	1	Strategy principles; alignment matrix of every control to 5 HVMC objectives
Residual risk after controls, with effectiveness measurements and monitoring procedures	6–7	Residual score per risk, effectiveness %, KPI per control, monitoring cycle and escalation

Plan at a glance: 16 treatments · **$12,975** one-time + **$39,579**/year (of which $25,000 is insurance) · **153 staff hours** over 8 weeks. High risks fall from **5 to 0**; 3 risks are eliminated; the total weighted risk score falls from **147.6 to 55.9** (portfolio effectiveness **62%**). For the five quantified risks, controls costing $10,653/year cut expected annual loss by $1,948,007.

1. Mitigation Strategy and Business Alignment

1.1 Strategy principles

1. **See first.** Detection (C01) closes the top-ranked risk and makes every other control measurable.
2. **Protect the crown jewel.** Lock down and make recoverable the ePHI store and its network path (C02, C03, C05). These were the three highest-exposure items in the asset register.
3. **Remove what HVMC does not need.** Avoid risk by decommissioning the legacy server and taking test identities out of production (C13, C14). It's cheaper than protecting them.
4. **Harden identity, the shared dependency.** Every system depends on Entra ID (C04, C07, C08).
5. **Transfer the financial tail** that controls cannot remove (cyber insurance, contractor BAA).
6. **Accept only within appetite**, with a named owner and a review date.

1.2 HVMC business objectives

ID	Objective	How the plan supports it
O1	Continuous, safe patient care	Recovery within the BIA's 4-hour EHR RTO; segmentation protects dose and lab data integrity
O2	HIPAA compliance (avoid OCR penalties)	Closes HIPAA gaps G1–G8 (audit controls, access control, contingency plan, sanction policy, BAAs)
O3	Protect patient trust and HVMC reputation	Prevents and detects ePHI exposure; insider snooping deterred
O4	Financial sustainability	Positive ROSI; insurance caps catastrophic loss; low-value assets removed
O5	Secure migration of LIS and Pharmacy to Azure	Logging, segmentation, private storage and CA give a secure landing zone for LIS and Pharmacy before they move to Azure

1.3 Alignment matrix

Control	O1	O2	O3	O4	O5
C01 Central logging, alerting and flow logs	●	●	●		
C02 EHR storage network lockdown		●	●		
C03 Enforced network segmentation	●	●			
C04 Privileged access resilience	●	●			
C05 Ransomware-resilient recovery	●	●		●	
C06 Malware scanning for EHR uploads	●		●		
C07 Conditional Access and phishing-resistant MFA	●	●	●		
C08 Tenant hardening		●	●		
C09 EHR access auditing and owner review		●	●		
C10 Sanction policy and training tracking		●			
C11 Privacy Officer and breach procedure		●	●		

Control	O1	O2	O3	O4	O5
C12 Contractor lifecycle and BAA		●		●	
C13 Decommission legacy public server			●	●	
C14 Separate test from production		●			
T01 Cyber liability insurance				●	
A01 Formal acceptance — accidental deletion				●	
Controls supporting each objective	**6**	**12**	**8**	**5**	**0**

O5 (migration) is supported indirectly by C01–C03 and C07, which form the secure foundation the migrated systems will sit on. It is listed as a direct objective only where a control is a migration prerequisite.

2. Control Selection Using NIST CSF 2.0 and ISO/IEC 27001:2022

2.1 Selection method

For each risk, candidate controls were drawn from the NIST CSF 2.0 subcategories and the ISO/IEC 27001:2022 Annex A controls that address its vulnerability. A control was selected if it (a) removes or reduces the specific evidenced vulnerability, (b) meets the BIA target where availability is involved, (c) costs less than the risk reduction it delivers, and (d) can be implemented with HVMC's existing staff and Azure services. Where a cheaper option eliminated the risk outright, avoidance was preferred over mitigation.

2.2 Selected controls

ID	Control	Strategy	Treats	NIST CSF 2.0	ISO/IEC 27001:2022 Annex A	Rationale
C01	**Central logging, alerting and flow logs** Log Analytics workspace; subscription activity log, storage and Entra audit logs via diagnostic settings; activity-log alert rules for NSG/policy/role changes; VNet flow logs	Mitigate	R01	DE.CM-01, DE.CM-09, DE.AE-02	8.15 Logging; 8.16 Monitoring activities	Closes the top-ranked risk; detection is a prerequisite for every other response. Required by HIPAA §164.312(b).
C02	**EHR storage network lockdown** Disable public network access and shared-key auth on hvmcehrstorage; private endpoint in HVMC-Data-Subnet; access only via Entra RBAC	Mitigate	R02	PR.AA-05, PR.DS-01, PR.IR-01	8.3 Information access restriction; 8.20 Networks security; 5.23 Cloud services	One leaked key currently exposes all ePHI; private access removes the internet path entirely.
C03	**Enforced network segmentation** Explicit Deny-All-VNet-Inbound (priority 4000) on Data and App NSGs; Azure Policy to audit NSGs lacking the rule	Mitigate	R03	PR.IR-01, PR.PS-01	8.22 Segregation of networks; 8.20 Networks security	Default AllowVnetInBound undoes the three-tier design; a deny rule restores it at zero licence cost.
C04	**Privileged access resilience** Two cloud-only break-glass Global Admins (offline credentials, sign-in alert); second named admin; Privileged Identity Management for just-in-time elevation	Mitigate	R04	PR.AA-05, GV.RR-02	8.2 Privileged access rights; 5.3 Segregation of duties	Removes the single point of failure found in the BIA; PIM needs Entra ID P2 for 2 admins (2 × $9/month).
C05	**Ransomware-resilient recovery** Blob versioning; 30-day soft delete; Azure Backup vaulted backup with immutability; quarterly restore test against BIA RTO 4 h / RPO 15 min	Mitigate	R05	PR.DS-11, PR.IR-03, RC.RP-01	8.13 Information backup; 8.14 Redundancy; 5.30 ICT readiness for business continuity	Versioning is off today, so encrypted blobs cannot be rolled back; this meets the BIA RPO.
C06	**Malware scanning for EHR uploads** Microsoft Defender for Storage with on-upload malware scanning; security contact email for alerts	Mitigate	R11	DE.CM-09, DE.AE-02	8.7 Protection against malware; 8.16 Monitoring activities	Files arrive from many clinical devices; scanning stops malware spreading through shared storage.
C07	**Conditional Access and phishing-resistant MFA** Entra ID P1 for 31 users; Conditional Access requiring phishing-resistant methods (passkeys in Microsoft Authenticator) for clinical and admin groups; sign-in risk blocking	Mitigate	R12	PR.AA-03, PR.AA-05	8.5 Secure authentication; 5.17 Authentication information	Security defaults allow push/OTP MFA that AiTM kits can proxy; passkeys are bound to the real sign-in site.
C08	**Tenant hardening** Disable user app registration and tenant creation; restrict guest invites to admins; admin consent workflow	Mitigate	R08	PR.AA-05, PR.PS-01	5.15 Access control; 8.9 Configuration management	Three insecure defaults found by the checklist; fixing them costs only configuration time.

ID	Control	Strategy	Treats	NIST CSF 2.0	ISO/IEC 27001:2022 Annex A	Rationale
C09	**EHR access auditing and owner review** Record-level EHR access logging; monthly review of unusual access by the system owner; reason-code prompt for out-of-unit records	Mitigate	R13	DE.CM-03, PR.AA-05	8.15 Logging; 5.18 Access rights	Snooping is the most common OCR complaint; visible auditing deters it and finds it early.
C10	**Sanction policy and training tracking** Written workforce sanction policy; annual HIPAA training with completion tracking	Mitigate	R14	PR.AT-01, GV.RR-04	6.4 Disciplinary process; 6.3 Information security awareness, education and training	Required HIPAA standard (§164.308(a)(1)(ii)(C)) and an easy audit finding to close.
C11	**Privacy Officer and breach procedure** Designate a Privacy Officer; documented breach-risk assessment and 60-day notification procedure; annual breach tabletop	Mitigate	R16	GV.RR-02, RS.CO-02	5.2 Roles and responsibilities; 5.24 Incident management planning; 5.34 Privacy and protection of PII	HIPAA requires the role; a clear owner stops the §164.404 deadline being missed.
C12	**Contractor lifecycle and BAA** Business Associate Agreement with indemnification and proof of the contractor firm's cyber insurance; account end date and quarterly review	Transfer	R06	GV.SC-05, PR.AA-01	5.19 Supplier relationships; 5.20 Supplier agreements; 5.18 Access rights	Transfers liability for contractor-caused breaches to the contractor firm and its insurer; expiry limits exposure time.
C13	**Decommission legacy public server** Remove the 2014-era SSH/Apache host from service and from DNS; migrate any needed content to a supported, patched platform	Avoid	R09, R10	ID.AM-08, PR.PS-02	8.8 Management of technical vulnerabilities; 5.9 Inventory of information assets	The server holds no ePHI and supports no business process; removing it eliminates both CVE risks for less than patching cost.
C14	**Separate test from production** Delete Test Nurse - EHR from the production tenant; run tests in a separate non-production subscription with synthetic data	Avoid	R07	PR.AA-01, PR.PS-01	8.31 Separation of development, test and production environments	Eliminates a shared identity with ePHI access instead of trying to control it.
T01	**Cyber liability insurance** Cyber policy with $5M limit and $100K retention covering breach response, notification, regulatory defence and business interruption	Transfer	R02, R05	GV.RM-04	5.19-adjacent (risk financing; outside Annex A)	Moves the financial tail of residual breach and ransomware losses to an insurer after controls lower the premium.
A01	**Formal acceptance — accidental deletion** Accept: weighted score 5.8 (Low) is within appetite; two experienced admins; RA-GRS keeps data if resources are rebuilt. Review annually.	Accept	R15	GV.RM-02	Clause 6.1.3 (risk owner acceptance)	Treatment cost would exceed benefit for a Low risk; acceptance is documented with a review trigger.

2.3 Framework coverage

NIST CSF 2.0 function	Treatments
Govern (GV)	6
Identify (ID)	1
Protect (PR)	11
Detect (DE)	3
Respond (RS)	1
Recover (RC)	1

The plan covers all six CSF 2.0 functions. It is weighted toward Protect and Detect, which matches the gaps found in the assessment. ISO 27001 coverage spans organizational (5.x), people (6.x) and technological (8.x) controls.

3. Cost-Benefit Analysis

Costing basis: internal labour $75/hour. One-time costs are amortized over 3 years: *annualized cost = annual cost + one-time cost ÷ 3*. Licence prices are approximate Microsoft list prices (Entra ID P1 ≈ $6 and P2 ≈ $9 per user per month; Defender for Storage ≈ $10 per account per month plus scanning; Log Analytics by GB ingested). Insurance terms are assumptions. Verify all prices before budgeting.

3.1 Quantified risks (ALE)

$$\text{ROSI} = (\text{ALE before} - \text{ALE after} - \text{annualized cost}) \div \text{annualized cost}$$

Risk / control	ALE before	ALE after	Reduction	Annualized cost	Net benefit	ROSI	Payback (days)
R01 via C01 Central logging, alerting and flow logs	$864,926	$345,971	$518,956	$931	$518,025	556×	1.3
R02 via C02 EHR storage network lockdown	$600,643	$120,129	$480,515	$490	$480,025	980×	0.9
R05 via C05 Ransomware-resilient recovery	$1,057,132	$288,309	$768,824	$2,800	$766,024	274×	0.6
R12 via C07 Conditional Access and phishing-resistant MFA	$168,180	$38,441	$129,739	$2,632	$127,107	48×	3.4
R13 via C09 EHR access auditing and owner review	$74,960	$24,987	$49,974	$3,800	$46,174	12×	4.4
Total			**$1,948,007**	**$10,653**	**$1,937,354**		

ALE figures come from the Risk Assessment Techniques model (asset value based on IBM 2025 healthcare breach cost + HIPAA annual cap). The ROSI values are very large because a single breach costs far more than these controls. Even if ALE were overstated tenfold, every control would still pay for itself.

3.2 Risk transfer — cyber insurance (T01)

Residual ALE after controls (R02 + R05)	$408,437
Share covered above the $100,000 retention (assumption)	80%
Expected annual recovery	$326,750
Annual premium (assumption; $5,000,000 limit)	$25,000
Net expected benefit	**$301,750**

Insurance is bought **after** controls, because insurers now require MFA, backups and logging, and price premiums on them. Insurance does not lower likelihood or the non-financial factors, so it changes only the financial exposure, not the weighted risk score.

3.3 Cost-effectiveness of every treatment

Treatment	Strategy	One-time	Annual	Annualized	Score reduction	Cost per point
C01 Central logging, alerting and flow logs	Mitigate	$1,800	$331	$931	9.98	$93
C02 EHR storage network lockdown	Mitigate	$1,200	$90	$490	7.84	$62
C03 Enforced network segmentation	Mitigate	$600	$0	$200	9.04	$22
C04 Privileged access resilience	Mitigate	$600	$216	$416	6.48	$64
C05 Ransomware-resilient recovery	Mitigate	$1,200	$2,400	$2,800	5.01	$559
C06 Malware scanning for EHR uploads	Mitigate	$150	$210	$260	4.80	$54
C07 Conditional Access and phishing-resistant MFA	Mitigate	$1,200	$2,232	$2,632	5.94	$443

Treatment	Strategy	One-time	Annual	Annualized	Score reduction	Cost per point
C08 Tenant hardening	Mitigate	$300	$0	$100	5.94	$17
C09 EHR access auditing and owner review	Mitigate	$600	$3,600	$3,800	2.78	$1,367
C10 Sanction policy and training tracking	Mitigate	$900	$500	$800	1.97	$406
C11 Privacy Officer and breach procedure	Mitigate	$1,200	$5,000	$5,400	3.39	$1,593
C12 Contractor lifecycle and BAA	Transfer	$1,950	$0	$650	2.63	$247
C13 Decommission legacy public server	Avoid	$300	$0	$100	22.33	$4
C14 Separate test from production	Avoid	$300	$0	$100	3.56	$28
T01 Cyber liability insurance	Transfer	$600	$25,000	$25,200	12.85	—
A01 Formal acceptance — accidental deletion	Accept	$75	$0	$25	0.00	—

The cheapest risk reduction per point comes from configuration changes and eliminations (C13, C08, C03, C14). The most expensive per point are people-heavy controls (C09, C11), which are justified by HIPAA requirements rather than score reduction alone.

3.4 Budget summary

Phase	Treatments	One-time	Annual
Phase 1 — Quick wins & eliminations (Oct 19 – Nov 01)	C02, C03, C04, C08, C12, C13, C14, A01	$5,325	$306
Phase 2 — Detection, recovery & policy (Nov 02 – Nov 22)	C01, C05, C06, C10	$4,050	$3,441
Phase 3 — Identity, auditing & risk transfer (Nov 16 – Dec 13)	C07, C09, C11, T01	$3,600	$35,832
Total		**$12,975**	**$39,579**

4. Risk Treatment Options — All Four Strategies

Strategy	When HVMC uses it	Applied to	Conditions and how it works here
Mitigate	Risk is worth keeping the activity for, and a control reduces likelihood or impact cost-effectively	R01, R02, R03, R04, R05, R08, R11, R12, R13, R14, R16	11 technical and administrative controls (C01–C11)
Avoid	The activity creating the risk has little or no business value	R07, R09, R10	**C13**: decommission the legacy public server (no ePHI, no business process). **C14**: remove the shared test account and run tests in a separate subscription. Both eliminate the risk entirely.
Transfer	A financial or legal consequence remains that another party can carry better	R02, R05, R06	**T01**: cyber insurance for residual breach and ransomware costs. **C12**: BAA with indemnification and proof of the contractor firm's insurance. Accountability for HIPAA compliance itself cannot be transferred.
Accept	Residual risk is within appetite and further treatment costs more than it saves	R15 (+ all residuals)	**A01**: R15 (Low, 5.8) accepted by Kevin O'Brien, reviewed annually or if admins exceed 4. All residual risks are formally accepted (Section 6.3).

4.1 Treatment plan for all 16 risks

Risk	Title	Inherent	Strategy	Controls	Risk owner	Due
R01	Security incident goes undetected for months (no central logging or alerting)	High	Mitigate	C01	Fatima Ali	Nov 15
R02	ePHI exfiltration from EHR storage over the public internet	High	Mitigate + Transfer	C02, T01	Fatima Ali	Dec 13
R03	Lateral movement from Web tier to Data tier	High	Mitigate	C03	Fatima Ali	Oct 25
R04	Loss or takeover of the only Global Administrator account	Medium	Mitigate	C04	Sabitha S Karanavar	Oct 25
R05	Ransomware or malicious deletion destroys EHR data	High	Mitigate + Transfer	C05, T01	Fatima Ali	Dec 13
R06	Contractor retains access after engagement ends; no BAA	Low	Transfer	C12	Kevin O'Brien	Nov 01
R07	Shared test account in production can read ePHI	Low	Avoid	C14	Sabitha S Karanavar	Oct 25
R08	Consent phishing or rogue app via open tenant settings	Medium	Mitigate	C08	Sabitha S Karanavar	Oct 25
R09	Remote code execution via OpenSSH 6.6.1p1 (CVE-2023-38408, CVSS 9.8)	Medium	Avoid	C13	Kevin O'Brien	Nov 01
R10	Remote code execution via Apache 2.4.7 mod_lua (CVE-2021-44790, CVSS 9.8)	High	Avoid	C13	Kevin O'Brien	Nov 01
R11	Malware uploaded to EHR storage is not detected	Medium	Mitigate	C06	Denise Coleman	Nov 15
R12	Clinician credentials stolen by MFA-bypass (AiTM) phishing	Medium	Mitigate	C07	Denise Coleman	Dec 13
R13	Workforce member views patient records without a care need (snooping)	Medium	Mitigate	C09	Denise Coleman	Dec 13

Risk	Title	Inherent	Strategy	Controls	Risk owner	Due
R14	Workforce violations go unpunished; training not tracked	Low	Mitigate	C10	Daniel Osei	Nov 15
R15	Accidental deletion of production network or storage	Low	Accept	A01	Kevin O'Brien	Oct 25
R16	Breach notification deadline missed (no Privacy Officer)	Medium	Mitigate	C11	Denise Coleman	Dec 06

5. Implementation Timeline and Resource Requirements

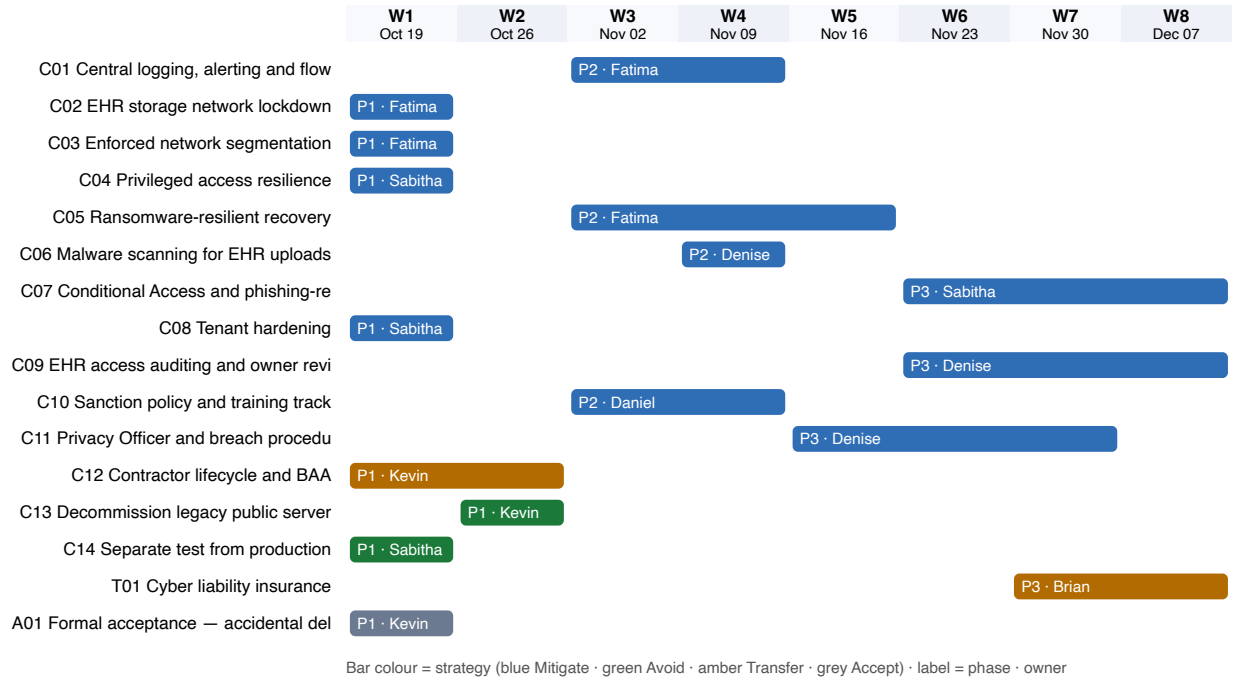


Figure 1 — 8-week implementation schedule (week 1 begins October 19, 2026).

5.1 Staff resources

Owner	Hours	One-time cost	Treatments
Fatima Ali	64 h	$4,800	C01, C02, C03, C05
Sabitha S Karanavar	32 h	$2,400	C04, C07, C08, C14
Denise Coleman	26 h	$1,950	C06, C09, C11
Daniel Osei	12 h	$900	C10
Kevin O'Brien	11 h	$2,325	C12, C13, A01
Brian Adeyemi	8 h	$600	T01
Total	**153 h**	**$12,975**	

Capacity check: Fatima Ali carries the most hours, mostly in Phases 1–2. That is about 8–10 hours a week alongside normal duties, which is feasible. Phase 3 items owned by Sabitha S Karanavar and Denise Coleman start only after the quick wins are done.

5.2 Licences, services and external resources

Item	Needed for	Approx. annual cost
Log Analytics ingestion (~10 GB/month)	C01	$331
Private endpoint for hvmcehrstorage	C02	$90
Entra ID P2 × 2 admins (PIM)	C04	$216
Versioning storage + vaulted backup; restore drills	C05	$2,400

Item	Needed for	Approx. annual cost
Defender for Storage + malware scanning	C06	$210
Entra ID P1 × 31 users (Conditional Access)	C07	$2,232
Legal review of BAA	C12	$1,500 one-time
Cyber liability insurance	T01	$25,000

Entra ID P1 also unlocks sign-in log export for C01, and is required for Conditional Access, which security defaults cannot provide.

6. Residual Risk and Control Effectiveness

6.1 Method

$$\text{Residual score} = \text{residual likelihood} \times \Sigma(\text{weight}_i \times \text{residual factor score}_i) \quad \cdot \quad \text{Effectiveness} = 1 - \text{residual} \div \text{inherent}$$

The same weights (Financial 19%, Operational 36%, Compliance 33%, Reputation 12%), bands and critical-factor floor from Risk Evaluation Methods are used, so inherent and residual scores are directly comparable. Preventive controls lower **likelihood**; detective and recovery controls lower **impact** factors.

6.2 Results

Risk	Title	Controls	Inherent	Res. L	Res. F/O/C/R	Residual	Effect.	Why it drops
R01	Security incident goes undetected for months (no central logging or alerting)	C01	16.64 High	2	3/3/4/3	**6.66** Medium	**60%**	Alerts cut dwell time from months to hours (lower impact) and deter attackers (L 4→2)
R02	ePHI exfiltration from EHR storage over the public internet	C02, T01	11.76 High	1	5/2/5/5	**3.92** Low	**67%**	No internet path to storage; exploitation needs an insider with RBAC (L 3→1)
R03	Lateral movement from Web tier to Data tier	C03	13.56 High	1	5/4/5/4	**4.52** Low	**67%**	Deny rule leaves only SQL 1433 from the App tier (L 3→1)
R04	Loss or takeover of the only Global Administrator account	C04	9.72 Medium	1	3/4/3/2	**3.24** Low	**67%**	Break-glass and second admin remove lockout; PIM removes standing privilege (L 3→1)
R05	Ransomware or malicious deletion destroys EHR data	C05, T01	14.01 High	3	3/3/3/3	**9.00** Medium	**36%**	Attacks still likely, but versioned, immutable backups cap outage within MTD (impact 5→3)
R06	Contractor retains access after engagement ends; no BAA	C12	4.60 Low	1	2/1/3/2	**1.97** Low	**57%**	Expiry limits exposure; BAA moves liability to contractor firm (L 2→1, C 4→3)
R07	Shared test account in production can read ePHI	C14	3.56 Low	—	—	**0.00** Eliminated	**100%**	Account removed — risk eliminated
R08	Consent phishing or rogue app via open tenant settings	C08	8.91 Medium	1	3/2/4/3	**2.97** Low	**67%**	Users can no longer register or consent to apps (L 3→1)
R09	Remote code execution via OpenSSH 6.6.1p1 (CVE-2023-38408, CVSS 9.8)	C13	9.57 Medium	—	—	**0.00** Eliminated	**100%**	Server decommissioned — risk eliminated
R10	Remote code execution via Apache 2.4.7 mod_lua (CVE-2021-44790, CVSS 9.8)	C13	12.76 High	—	—	**0.00** Eliminated	**100%**	Server decommissioned — risk eliminated
R11	Malware uploaded to EHR storage is not detected	C06	10.08 Medium	2	3/2/3/3	**5.28** Low	**48%**	Uploads scanned before use (L 3→2, O 4→2)
R12	Clinician credentials stolen by MFA-bypass (AiTM) phishing	C07	8.91 Medium	1	3/2/4/3	**2.97** Low	**67%**	Phishing-resistant MFA defeats AiTM proxies (L 3→1)
R13	Workforce member views patient records without a care need (snooping)	C09	7.62 Medium	2	2/1/4/3	**4.84** Low	**36%**	Auditing deters and detects early (L 3→2, R 4→3); some snooping remains — residual accepted by owner
R14	Workforce violations go unpunished; training not tracked	C10	3.94 Low	1	2/1/3/2	**1.97** Low	**50%**	Policy and tracked training in place (L 2→1)

Risk	Title	Controls	Inherent	Res. L	Res. F/O/C/R	Residual	Effect.	Why it drops
R15	Accidental deletion of production network or storage	A01	5.82 Low	2	3/4/2/2	**5.82** Low	**0%**	Accepted — no change
R16	Breach notification deadline missed (no Privacy Officer)	C11	6.12 Medium	1	3/1/4/4	**2.73** Low	**55%**	Named Privacy Officer and procedure (L 2→1, C 5→4)
	Portfolio total		**147.6**			**55.9**	**62%**	

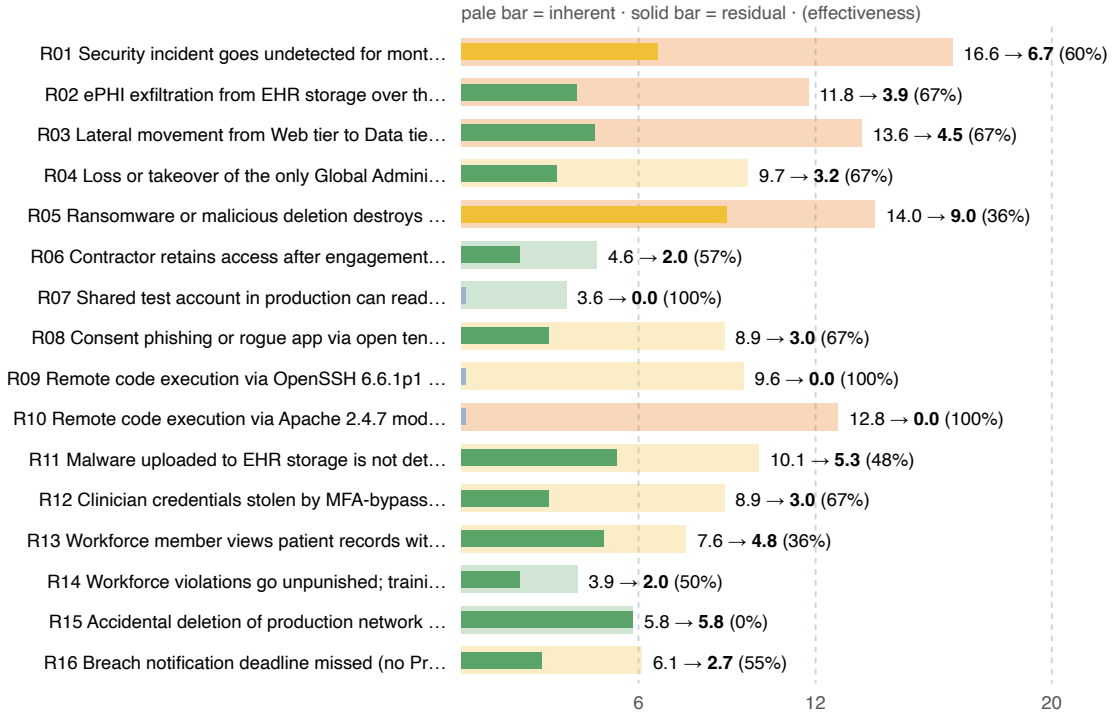


Figure 2 — Inherent vs residual weighted risk scores.

Residual profile: High 0 · Medium 2 · Low 11 · Eliminated 3. Two Medium residuals remain. **R05 (ransomware)** stays Medium because attacks will still happen; the controls cap the *outage* within the BIA MTD rather than preventing attempts. **R01** stays Medium because logging shortens detection but cannot stop intrusions. Both are within appetite for owner acceptance.

6.3 Residual risk acceptance

Risk	Residual	Risk owner	Acceptance authority (per appetite)	Signature
R01 Security incident goes undetected for months (no central logging or alerting)	6.66 Medium	Fatima Ali	System owner with Security & Risk Lead agreement	_____
R05 Ransomware or malicious deletion destroys EHR data	9.00 Medium	Fatima Ali	System owner with Security & Risk Lead agreement	_____
R15 Accidental deletion of production network or storage	5.82 Low	Kevin O'Brien	Risk owner (within appetite)	_____

All Low residuals are accepted by the Security Officer under the risk appetite (Risk Management Fundamentals §1.4). Signatures are left blank for this lab simulation.

7. Effectiveness Measurement and Monitoring Procedures

7.1 Effectiveness measures (KPIs) per control

Control	KPI	Target	Data source / test	Frequency	Owner
C01 Central logging, alerting and flow logs	Resources sending logs / alert-to-triage time	100% / < 15 min	az monitor diagnostic-settings list; test alert	Monthly	Fatima Ali
C02 EHR storage network lockdown	publicNetworkAccess / allowSharedKeyAccess	Disabled / false	az storage account show	Monthly	Fatima Ali
C03 Enforced network segmentation	Web→Data test on non-1433 port / Policy compliance	Blocked / 100%	Quarterly connectivity test; Azure Policy	Quarterly	Fatima Ali
C04 Privileged access resilience	Standing Global Admins / break-glass alert test	≤ 2 + break-glass / pass	Entra roles report; quarterly test sign-in	Quarterly	Sabitha S Karanavar
C05 Ransomware-resilient recovery	Restore test result vs RTO/RPO	≤ 4 h / ≤ 15 min	Quarterly restore drill record	Quarterly	Fatima Ali
C06 Malware scanning for EHR uploads	Scan coverage / alerts reviewed in SLA	100% / 100%	Defender for Cloud	Monthly	Denise Coleman
C07 Conditional Access and phishing-resistant MFA	Users covered by CA / phishing-resistant registration	100% / ≥ 90%	Entra authentication-methods report	Monthly	Sabitha S Karanavar
C08 Tenant hardening	authorizationPolicy settings	allowedToCreateApps=false; invites=admins	Graph authorizationPolicy	Monthly	Sabitha S Karanavar
C09 EHR access auditing and owner review	Monthly reviews completed / unexplained accesses	100% / 0 open > 30 days	Review log	Monthly	Denise Coleman
C10 Sanction policy and training tracking	Training completion	≥ 95% annually	HR training records	Quarterly	Daniel Osei
C11 Privacy Officer and breach procedure	Breach assessments completed within 5 days	100%	Incident records; tabletop report	Annually + per incident	Denise Coleman
C12 Contractor lifecycle and BAA	Contractor accounts with end date / BAA on file	100% / yes	Entra user report; contract register	Quarterly	Kevin O'Brien
C13 Decommission legacy public server	Internet scan of former host	0 open ports	nmap from outside	Once, then quarterly	Kevin O'Brien
C14 Separate test from production	Test/shared accounts in production	0	Entra user list	Monthly	Sabitha S Karanavar
T01 Cyber liability insurance	Policy in force / coverage vs residual ALE	Yes / ≥ 100%	Insurance certificate	Annually	Brian Adeyemi
A01 Formal acceptance — accidental deletion	Number of admins / incidents	≤ 4 / 0	Entra roles; incident log	Annually	Kevin O'Brien

7.2 Monitoring procedure

Cycle	Activity	Responsible
Continuous	C01 alert rules notify the Security Monitoring Portal of NSG, role, policy and storage-setting changes	Anthony Ruiz
Monthly	Re-run the 27-item CIS-aligned Azure checklist from Risk Assessment Techniques (read-only `az` queries); record each KPI as Green / Amber / Red in the workbook	Anthony Ruiz → Denise Coleman
Quarterly	Operating-effectiveness tests: restore drill (C05), break-glass sign-in alert (C04), Web→Data blocked-port test (C03), contractor access review (C12); re-score residual risk; log changes in the register History sheet	Control owners; Denise Coleman

Cycle	Activity	Responsible
Annually	Review strategy, weights, appetite and accepted risks; renew insurance; update BIA	Executive Risk Committee
Event-driven	Re-assess after any incident, new system (LIS/Pharmacy migration) or regulatory change	Denise Coleman

7.3 Escalation of control failures

- **Amber** (KPI missed once): owner fixes within 30 days; noted in the monthly report.
- **Red** (KPI missed twice, or a test fails): treated as a High risk under the escalation matrix. Plan within 7 days, reported to the Executive Risk Committee.
- A control failure that re-opens a risk to its inherent level resets that risk's residual score in the register until re-tested.

8. Conclusion

The plan treats all 16 risks with 16 documented treatments covering all four strategies. Each is mapped to NIST CSF 2.0 and ISO/IEC 27001:2022 and justified by a measured gap. For $12,975 one-time and $39,579 per year, High risks fall from 5 to 0, three risks are eliminated, and the weighted portfolio score falls by 62%. Every control has a KPI, an owner and a monitoring cycle, so effectiveness can be shown rather than assumed. These results feed the next rubric, **Risk Communication**, which will present them as an executive report and dashboard.

References

- NIST, *The NIST Cybersecurity Framework (CSF) 2.0*, NIST CSWP 29 (February 2024).
- ISO/IEC 27001:2022 *Information security management systems — Requirements* (Annex A) and ISO/IEC 27002:2022.
- ISO 31000:2018 *Risk management — Guidelines* (risk treatment options).
- NIST SP 800-37 Rev. 2; NIST SP 800-53 Rev. 5.
- 45 CFR Part 164 Subpart C (HIPAA Security Rule).
- Microsoft Learn: Azure Monitor pricing, Microsoft Entra ID licensing, Defender for Storage pricing, Azure Backup for blobs.
- HVMC project evidence: HVMC_Risk_Assessment_Techniques.pdf; HVMC_Risk_Evaluation_Methods.pdf; HVMC_Risk_Register.xlsx.